

Méthode de STRIDE

Objectif: Utiliser la méthode STRIDE pour la modélisation des menaces et l'élaboration de l'architecture du système, en intégrant les mesures de sécurité spécifiques suggérées par STRIDE. (Utilisation de l'[OWASP Threat Modeling Process](#))

1. Décomposition du Système et Périmètres de Confiance

- **Frontière Externe :** Entre l'utilisateur et les processus de validation.
- **Frontière de Service Tierce :** Entre l'orchestrateur et l'API de recettes / Modèle d'IA.
- **Frontière de Persistance :** Entre les processus de calcul et les bases de données (Utilisateurs et Graphe/Vecteur de similarité).

2. Analyse des Menaces STRIDE par Composant

a. Flux de Données et Processus d'Entrée

Menace	Description	Mesure de sécurité
Spoofing	Usurpation d'identité d'utilisateur par injection de session lors de la soumission de données brutes.	Implémentation de jetons CSRF et gestion de session sécurisée (cookies et JWT sécurisé).
Tampering	Modification des données de l'utilisateur pendant le transit pour le nuire.	Utilisation impérative de TLS 1.3 pour tout flux de données.
Repudiation	Déni de soumission de données brutes erronées ou malveillantes par l'utilisateur.	Journalisation des tentatives de soumission avec horodatage et IP source (en respectant le RGPD).

Information Disclosure	Fuite de données personnelles sensibles lors de la phase de validation.	Chiffrement au repos des logs de validation et masquage des données sensibles.
Denial of service	Envoi massif de données complexes pour saturer le processus de normalisation.	Mise en place de Rate Limiting par IP et validation de la taille des payloads.
Elevation of privilege	Contournement des mécanismes de validation par injection de payloads malformés pour l'accès aux fonctions système internes.	Architecture de type Chokepoint (aucun flux ne contourne le validateur) et exécution du processus de validation avec un compte à privilèges restreints.

b. Stockage des Données

Menace	Description	Mesure de sécurité
Spoofing	Usurpation d'identité au niveau de la connexion à la base de données.	Authentification forte entre l'application et la BDD.
Tampering	Injection SQL ou manipulation du graphe/vecteur de similarités afin de biaiser les recommandations.	Utilisation de requêtes préparées (ORM) et validation d'intégrité des vecteurs.
Repudiation	Dénégation de modification des contraintes alimentaires par l'utilisateur suite à un incident de santé.	Journalisation immuable et horodatée de chaque modification de profil.
Information Disclosure	Accès non autorisé à la base de données révélant le profil nutritionnel global.	Chiffrement transparent de la base de données et principe du moindre privilège pour les comptes.

Denial of service	Saturation de la base de données par des requêtes de recherche de similarités trop lourdes.	Mise en place de quotas de requêtes par utilisateur et optimisation des index vectoriels pour limiter la charge CPU.
Elevation of privilege	Accès non autorisé aux vecteurs de similarités tiers par exploitation d'une vulnérabilité IDOR par un utilisateur authentifié.	Contrôle d'accès basé sur les attributs (ABAC) pour vérifier la propriété de la donnée avant lecture.

c. Orchestration et Services Tiers

Menace	Description	Mesure de sécurité
Spoofing	Détournement de l'API de recettes par une attaque de type MITM pour l'injection de recettes malveillantes ou empoisonnées.	Validation des certificats SSL/TLS de l'API tiers et authentification par clé API sécurisée.
Tampering	Prompt Injection sur le modèle d'IA pour contourner les filtres de sécurité nutritionnels.	Sanitization stricte des entrées envoyées à l'IA et filtrage des sorties par un système de règles déterministe.
Repudiation	Impossibilité de savoir si une recommandation dangereuse vient de l'API tiers ou d'une erreur interne.	Audit complet des appels sortants et entrants vers les API tierces (Request/Response logging).
Information Disclosure	Divulgateion de données personnelles par mémorisation et restitution non autorisée via le modèle d'IA (Attaque par inférence).	Anonymisation des données envoyées au modèle d'IA pour l'affinage.
Denial of service	Épuisement des ressources par des requêtes de recherche hybride complexes et récursives.	Timeout strict sur les appels API et mise en cache sécurisée des résultats fréquents.

Elevation of privilege	Exploitation de l'orchestrateur pour exécuter du code arbitraire (RCE) sur le serveur, passant d'un accès applicatif à un accès Administrateur.	Isolation par conteneurs et utilisation d'un noyau kernel durci.
------------------------	---	--

3. Architecture de Sécurité

→ Couche d'Accès et Identité

- ◆ **Authentification Forte** : Utilisation d'OAuth2/OpenID Connect pour l'utilisateur authentifié.
- ◆ **Zero Trust** : Chaque processus doit ré-authentifier la requête via un service de jetons interne (JWT).

→ Couche de Traitement (Fail-Safe)

- ◆ **Validation de Sortie**: Le processus "Filtrer et valider les résultats" doit agir comme un pare-feu nutritionnel. Si une recette contient un ingrédient marqué comme "allergie" dans la base de données, elle doit être bloquée, peu importe la suggestion de l'IA.
- ◆ **Isolation de l'IA** : Le modèle d'IA est considéré comme une boîte noire potentiellement compromise. Aucun accès direct à la base de données utilisateur ne lui est accordé, il ne reçoit que des critères anonymisés.



→ Couche de Données

- ◆ **Séparation des Données** : Ségrégation logique ou physique entre les données d'identité et les données de santé pour limiter l'impact d'une fuite.
- ◆ **Audit Trail** : Stockage des logs dans un SIEM (Security Information and Event Management) pour détecter les comportements anormaux.